

Athens, 06-02-2025

No. Protocol: 511

DECISION 7/2025

The President of the Authority, as a single-member body pursuant to Article 17 paragraph 1 of Law 4624/2019 (Government Gazette A' 137), within the framework of the powers provided for in Articles 4 paragraph 3 subparagraph a and 10 paragraph 4 of the Operating Regulation of the Authority (Government Gazette B' 879/25.02.2022) and the powers stipulated in Article 15 paragraph 8 of Law 4624/2019 in conjunction with Article 58 paragraph 2 subparagraph e of Regulation (EU) 2016/679 (General Data Protection Regulation – hereinafter GDPR), examined the incident of breach, which is referred to below in the background of this decision.

The Authority took into account the following:

A notification of a breach was submitted to the Authority under protocol number G/EIΣ/11373/27-10-2022 by the company "ALPHA BANK ANONYMOUS COMPANY" (hereinafter "the company"), in which it is stated that an incident of unauthorized access to personal data occurred by an employee of the company (hereinafter "employee"). According to the notification, the incident became known through a report from executives of the General Directorate to the Reporting Evaluation Committee on 07.10.2022 and arose as a consequence of the inadvertent retention of the system administrator role by the employee, who had been internally transferred to another department. The exploitation of this oversight led to a breach of confidentiality for the data of 6,176 bank employees. The notification of the incident was delayed as an investigation was required to identify the source of the data leak and to confirm the breach.

Subsequently, the company sent the memorandum under protocol number G/EIΣ/681/27-01-2023, stating that:

1. The incident was due to non-compliance with the company's internal security procedures.
2. The employee inadvertently continued to maintain an account with administrative rights (System Administrator), despite the fact that on 01.01.2015 they ceased to hold the position of system administrator and were transferred to another department (Cybersecurity Directorate).
3. Following the above finding of unauthorized access by the Internal Audit Directorate, all access rights of the employee to all systems of the Bank were revoked on the same day (07.10.2022), and the employee was placed on mandatory leave.
4. Due to the number of unauthorized recorded actions (logs) of the employee that were identified as well as the content of the email messages and their pathways that needed to be investigated and consequently the potential risk to the rights of the data subjects, it was decided to seek the assistance of a specialized company for the further investigation of the incident and its consequences. The company Alvarez & Marsal was selected, which sent specialized personnel from the UK to Greece, who, in full cooperation with the Internal Audit Directorate of the Bank and using specialized software, conducted an investigation.
5. In the context of this investigation, an email was identified that included the payroll data of all Bank personnel (6,167 individuals), as well as evaluations, family status information, prior employment details, and retirement eligibility conditions, which the employee had retrieved from the email archiving system (Enterprise Vault). The Enterprise Vault was integrated into the Privileged Access Management system.

1 The Privileged Access Management (PAM) is an identity security solution that helps protect organizations from cyber threats by monitoring, detecting, and preventing unauthorized privileged access to critical resources. PAM operates through a combination of people, processes, and technology and provides visibility into who is using privileged accounts and what they are doing while logged in. Limiting the number of users who have...

Management – hereinafter referred to as "RAM") in which the actions of the administrators carried out through remote desktop connections on the servers are recorded, starting from January 2022. This inclusion pertains to the administrators of the Information Systems Directorate, but not to those of the

Cybersecurity and Information Security Directorate.

6. From March 2019 until October 7, 2022, when it was interrupted, any access capability was found to have occurred, except for the period in December 2021 during which no access was recorded. The employee made 24,625 unauthorized actions (logged actions) in the Enterprise Vault either to view only the content of the emails or to obtain the corresponding file. It is noted that in December 2021, the passwords were changed, resulting in the interruption of the aforementioned employee's activity until February 2022, when, presumably with the collaboration of another employee of the Bank, the passwords to the Enterprise Vault system came back to his knowledge.

7. The employee sent 116 messages containing information that came into his possession through his unauthorized access to the email system to 8 other employees of the Bank, either by proactively sending them himself or following their recorded electronic requests. Notably, the recipient of most messages received forty-three (43) of them, while the recipient of the fewest received one (1) message. Of these: fifty-three (53) messages contained personal data concerning employees of the Bank, one (1) message concerned personal data of individuals outside the Bank and specifically included the resumes of eighteen (18) subjects submitted for filling a job position at the Bank (year 2020), eight (8) messages concerned requests from some of the 8 operators to the employee for the provision of information, while the remaining fifty-four (54) messages did not contain personal data as they concerned organizational changes of the Bank (Action Plans, Operating Regulations, etc.).

8. The above conclusions of the investigation were communicated, and the aforementioned nine (9) total operators of the Bank (the employee and the 8 recipients) were summoned for explanations and subsequently agreed to voluntarily leave the Bank, undertaking a written obligation of full cooperation with the Bank, within which they undertook, among other things, to return the files with personal data that came into their possession during their employment at the Bank, to return the terminals (PCs), laptops, keys, data encryption passwords, access passwords, or other means of access to areas or systems of the Bank that they used during their employment, etc. However, primarily, they left the Bank after undertaking a written obligation of full confidentiality regarding the incident, for the compliance control of which they accepted the gradual payment of their legal severance compensation over a twelve-month period.

Furthermore, the company submitted the notification of the incident of violation under protocol number G/EIS/2545/05-04-2023, additionally stating that the unauthorized access concerns health data, namely disability percentage in the context of managing the employment relationship, and finalizing the number of persons and files affected by the incident. Finally, the company submitted the supplementary memorandum under protocol number G/EIS/2546/05-04-2023, providing the following summary table with the personal data of the employees of the Bank to which there was unauthorized access by category:

Number of Messages Personal Data Number of Individuals Up to 14.12.2022 After 14.12.2022	
----- ----- ----- ----- -----	
41 6 Payroll data of staff, extraordinary benefits (bonus), age, work experience, evaluations, training, recruitment channel, health data - disability percentage, marital status, age/date of birth, voluntary exit data of staff (VSS) (data from 2019/20/21/22) up to 6167 5	
3 Exit data of staff (VSS) (years 2020, 2021) up to 229 4 3	
138 Staff evaluations for the years 2020, 2021, and 2022 up to 138 1 -	
86 Salaries of Directors of Directorates (data from 2019) 1 -	
253 Directors and Deputy Directors of Directorates with comments on the voluntary exit (data from 2020) 1 -	
118 Promotions and evaluations of executives (data from 2020) 53 11	
Total Messages 64 **Maximum number of affected Individuals (Bank operators)** 6167	
Messages without personal data	
Up to 14.12.2022 After 14.12.2022 Content of messages without personal data Number of individuals	
54 17 Organizational changes, Action Plans, Operating Regulations (2019 to 2022) -	
8 4 Requests to employee for provision of information -	

The company was summoned to a hearing before the President of the Authority on February 8, 2024, with the document number G/EXE/451/31-01-2024 from the Authority. The meeting was attended on behalf of the data controller by Ioannis Mourgelas, Legal Advisor (AM DSA ...), Nikolaos Salakas, Legal Advisor (AM DSA ...), A, head of the compliance department, and B, Data Protection Officer, who...

asserted the following:

1. The incident was perceived because in September 2022, there was a sense within the company's management that there was a leak of information regarding payroll from the IT department, as it appeared that some individuals were aware of certain changes that they should not have been.
2. It was found that the employee had retrieved from the Enterprise Vault system, without authorized access, an email containing payroll information.
3. There was a company policy for revoking roles that was not implemented.
4. The investigation revealed that from 2019 to 2022, the employee had 24,625 unauthorized accesses and downloaded 64 emails from the Enterprise Vault system. Of these, 63 concerned personal data of company employees, and one included resumes of candidates related to job postings.
5. The employee forwarded the emails to a group of eight recipients.
6. The involved operators were removed with termination of employment contracts and signed a confidentiality statement.
7. Fifteen months have passed since then, during which there were no indications of the use of the personal data to which the involved operators gained unauthorized access.
8. The employee had no reason to use the unauthorized access capability prior to 2019. Subsequently, there was motivation due to the change in the company's management and the resulting changes in personnel.
9. Following the incident, a series of new security measures were implemented, such as access to data only in cases where it is requested by more than one authorized user of the system, monitoring of accesses by an independent department of the company, etc. As a result of these additional technical measures, it is no longer possible to repeat the specific violation due to organizational error.

Finally, the company submitted memorandum no. Γ/ΕΙΣ/1433/22-02-2024, accompanied by the group security policy and the human resources management policy, which state, among other things,

1. the additional organizational and technical measures taken after the incident,
2. that after a thorough investigation in cooperation with an external partner, no indications of unauthorized accesses to the company's systems emerged until the first quarter of 2019.

The Authority, having taken into account the above,

CONSIDERED ACCORDING TO THE LAW

1. According to paragraph 1, subparagraph (f) of Article 5 of Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation – hereinafter GDPR), "personal data shall be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."
 2. According to Article 32 of the GDPR: "Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among others, as appropriate: (...) (b) the ability to ensure the confidentiality, integrity, availability and resilience of processing systems and services on a continuous basis, (...) (d) a process for regularly testing, assessing and evaluating the effectiveness of technical and organizational measures for ensuring the security of processing.
In assessing the appropriate level of security, particular consideration shall be given to the...

****Risks arising from processing, particularly from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that has been transmitted, stored, or otherwise processed.****

3. The data controller and the processor shall take measures to ensure that any natural person acting under the authority of the data controller or the processor who has access to personal data processes it only on the instructions of the data controller, unless required to do so by Union or Member State law.

3. In the case under examination, the evidence in the file indicates that due to the failure to implement the company's security policy, there was no adjustment of the employee's role in the system when transferring to another organizational position, in violation of Article 32 of the GDPR. Furthermore, due to the high privileges required by the employee's previous role (system administrator), the user in question maintained increased unauthorized access to system resources for a prolonged period. This specific security gap led to a type of access control violation, which, despite its limited scope (one user) and the fact that it falls under the category of internal threats, is considered a high-risk threat that exposes a system significantly. This failure to adjust roles went unnoticed for a very long time (2015-2022) and resulted in 6,167 natural persons being affected by the incident, with the information to which unauthorized access was gained also concerning personal data of special categories (health-disability percentage).

4. From the aforementioned security gap, it can be inferred that, in violation of Article 32 of the GDPR, the following measures were not implemented at the level of addressing internal threats:

- a. Adequate system monitoring,
- b. Implementation of security policies,

2 Access control enforces a policy so that users cannot act outside their granted permissions.

- c. Additional system monitoring at the level of administrator activities,
- d. Existence of technical measures that could, by definition, prevent organizational errors of this nature, such as automated changes at the software level or with database triggers that adjust system roles to changes in fields concerning organizational position modifications.

5. The company has a Privileged Access Management (PAM) system. The software used by the company to monitor communication channels and detect deviations (Enterprise Vault) was integrated into PAM in 2022 and does not monitor the activities of cybersecurity and information security administrators. If this integration had occurred earlier and involved all users/admins, the security gap might have been detected through this system, and the consequences could have been mitigated.

6. From the above data, a violation of the principle of confidentiality arises and, therefore, constitutes a breach of Article 5(1)(f) in conjunction with Article 32 of the GDPR.

7. Based on the previous considerations, the Authority deems it appropriate to exercise its corrective powers under Article 58(2) of the GDPR concerning the identified breach and that, based on the circumstances identified, an effective, proportionate, and deterrent administrative fine should be imposed in accordance with the provision of Article 58(2)(h) of the GDPR, pursuant to Article 83 of the GDPR.

8. Furthermore, the Authority took into account the criteria for imposing fines set out in Article 83(2) of the GDPR and paragraph 5(b) of the same article applicable to the present case, the Guidelines for the application and determination of administrative fines for the purposes of Regulation 2016/679 issued on 03-10-2017 by the Article 29 Working Party (WP 253), and the Guidelines 04/2022 of the European Data Protection Board for...

the calculation of administrative fines within the framework of the General Regulation⁴, as well as the actual data of the case under examination and particularly the following criteria:

I. As aggravating factors:

- a. That the employee had the ability for unauthorized access to the system with elevated system

administrator rights for a long period, during which this capability went unnoticed.

b. That particularly significant categories of personal data were affected, such as payroll data, extraordinary benefits (bonuses), age/date of birth, prior experience, education, recruitment channel, marital status, voluntary exit data of personnel, comments from directors and deputy directors regarding the voluntary exit, employee evaluations, salaries of department directors, promotions, and evaluations of executives.

c. That personal data of special categories were affected, such as health data - disability percentage.

II. As mitigating factors:

a. Following the incident, the company, within the framework of its compliance policy, undertook a series of actions to enhance security at both technical and organizational levels, in order to strengthen system security through the implementation of technical measures and to limit the possibility of the same incident recurring.

b. Following the incident, measures were imposed against the employees of the company involved in the leak of personal data.

c. Following the incident, an investigation was conducted in full cooperation with the Internal Audit Department of the Bank using specialized software from the company Alvarez & Marsal, which sent specialized personnel to Greece from the UK.

d. The leak of personal data as a consequence of the incident was of a minor scale and the consequences from the incident were limited relative to the size of the company.

III.

The last consolidated available turnover of the company (01/01/2022-30/06/2022) amounts to €2,194,008,000.

9. Following the consideration of the above aggravating and mitigating criteria (consideration 8 points i) and ii) above), as well as the turnover of the company (consideration 8 point iii) above), the severity of the identified violations is deemed to be minor. Therefore, the Authority deems that a fine should be imposed on the company named "ALPHA BANK ANONYMOUS COMPANY" close to the lower end of the static range defined by the guidelines 4/2022 of the EDPB for violations of minor severity, amounting to €3,000.

FOR THESE REASONS

The Authority

Exercising its corrective powers based on Article 58 paragraph 2 point (h) of the GDPR, imposes a fine of three thousand euros (€3,000) on the company named "ALPHA BANK ANONYMOUS COMPANY," for the reasons extensively outlined in the reasoning.

The President

The Secretary

Konstantinos Menoudakos

Irini Papageorgopoulou